

[doc. web n. 10074551]

Provision of October 17, 2024

Register of provisions

n. 620 of October 17, 2024

## THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stazione, President, Prof.

Ginevra Cerrina Feroni, Vice President, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing "Code regarding the protection of personal data, containing provisions for the adaptation of the national legislation to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD TO Legislative Decree No. 101 of August 10, 2018, containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC";

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Guarantor for the protection of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8, 2019 and on [www.gpdp.it](http://www.gpdp.it), doc. web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, doc. web n. 1098801;

Reporting Attorney Guido Scorza;

PREMISED

# 1. The complaint and the investigative activity

On XX, Ms. XX filed a complaint

alleging a violation of the regulations regarding the protection of personal data arising from the methods of delivery of online reports by Bios S.p.A. (hereinafter the "Company").

In particular, it was reported that the same

Company "by entering an incorrect email address, disseminated the report of diagnostic tests related to (minor daughter) ... (2 years old), which contained, in addition to the health data of the latter, also all the personal data of the same (place, date of birth, residence)", highlighting that the reports were "merely attached to the email without requiring a password for access to view them".

In the course of the investigative activity, it became necessary to request information useful for the assessment of the case from the Company (notes of XX and XX), which provided feedback (notes of XX and XX), stating that:

- "on XX, the operator of Bios received a phone call from the complainant in which she indicated that she had received via email only one report related to her first daughter and not that of her second daughter";
- "the operator verified during the call what had happened and realizing that the report had indeed not been attached, made a second sending. Shortly after, the lady called back again stating that she had not received the report, then the operator checking in real-time realized that he had manually sent the report to a different email, and immediately informed the interested party";
- "the sending subject, as per instructions, immediately contacted the erroneous recipient by phone indicating the erroneous sending and requesting the immediate deletion of the message";
- "the erroneous recipient stated that she had not opened the message (as she understood she was not the recipient, having not recently performed any service with the data controller), and similarly reassured the authorized processor that she had deleted the message containing the aforementioned report";
- "all this occurred within a span of about ten minutes. It seems plausible that no third party had the opportunity to view the particular data subject to the complaint. To prove the good faith of the company, it is stated that the circumstances just described were immediately communicated to the Lady (complainant) by the operator who then proceeded to the correct sending";
- what subsequent mitigation actions were taken: "specifically, during the week of October 7, training and specific instruction with a call for greater

attention from the authorized personnel"; "the company, in compliance with the principle of accountability and in accordance with Article 32, has implemented with respect to online reporting with password and in order to reduce the residual risk, a new procedure that will provide as soon as possible (...) the adoption of passwords for the sending of online reports";

- "in compliance with the aforementioned 2009 guidelines regarding security measures, what is provided for in scenario 2 is in use [the party has signed explicit consent for sending the report attached to the email, in pdf format, but without a password];
- "in the patient acceptance software, a pop-up appears that draws the operator's attention to the email address provided by the user, in order to allow for further verbal verification of the correctness of the address given";
- "on the invoice delivered at the end of the acceptance, the email address to which the client has requested the report to be sent is indicated, again to allow for further verification."

The aforementioned note was accompanied by several documents titled "Telematic Reporting Procedure," "Consent to the Processing of Personal Data," "Expression of Consent," "Acquisition of Consent," "Authorization for Data Processing - Acceptance."

In particular, in the document "Telematic Reporting Procedure," it is expressly stated that: "in the event that the interested party has decided to subscribe to the service, the operator must obtain specific consent, where it must be specified that the report will not be accompanied by a password. The situation in which it will not be possible to provide the credentials for opening the file to be sent via email can only occur when the interested party has expressly and knowingly requested to be sent the file without a key that allows its opening. It is also necessary, before completing an acceptance, to always verify once more the correctness of the email entered and to ask the client to read it also on the invoice where it appears" (point 5) and that "the organization also adopts the following security measures to ensure the protection of the data contained in the report: 1. The sending of the report as an attachment to an email message and not as text included in the body part of the message; 2. Validation of email addresses through a specific pop-up that reminds the operator to verify the correctness of the address, in order to avoid sending electronic documents to parties other than the user requesting the service."

Furthermore, in the document titled "Consent to the Processing of Data," at point 10 ("Specific Information for Sending Reports via Email"), it is indicated that "It is informed that the Bios Group S.P.A is able to provide a copy of the report of the services performed via email, in pdf format without the use of a password, to the email address provided by the interested party. This service, which is optional, can be provided with the consent of the interested party either permanently or related to a single acceptance."

2. Evaluations of the Department on the processing carried out and notification of the violation referred to in Article 166, paragraph 5 of the Code

In relation to the facts described in the complaint, the Office, with note dated XX (prot. n. XX), notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, inviting it to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

In particular, the Office, in the aforementioned act, considered that the Company, at the time of the complaint, had not complied with the obligations set forth in Article 32 of the Regulation, as appropriate technical and organizational measures had not been adopted to ensure a level of security adequate to the risks presented by the processing and, therefore, in violation of the basic principles of processing referred to in Articles 5, paragraph 2, letter f), 25, paragraph 1, and 32 of the Regulation.

The Company requested to be heard in a hearing, which took place on XX, during which it was highlighted that:

- "Bios S.p.A. is adapting all information systems with an encrypted code to be provided to clients for access to the report, attached to the recipient's email; this adjustment activity will be completed in a few weeks; the Authority will be informed of the date of completion of the adjustment";
- "Bios S.p.A. provides laboratory service activities for public and private structures in the Lazio region and beyond, and in the context of this activity, has long been sending reports protected by a password since the sending occurs from a more recent and streamlined software program, different from that used for patients of the structure";
- "Bios S.p.A. is constantly committed to implementing its information systems to ensure the efficiency of the services offered to clients, also in terms of security and data protection";
- "in this case, an operator manually entered the patient's email for a new sending of the report and, realizing a material error, communicated the error to the patient. At the same time, the incorrect recipient was contacted by phone to request the immediate deletion of the email received";
- "in cases of patient acceptance, the operator sees an automatic pop-up that alerts them to further check the correctness and currency of the email address, and, in this specific case, the operator did not see the pop-up as they were manually sending it following a call from the client and not during the acceptance phase."

### 3. Outcome of the investigative activity

Taking into account what was represented by the Company in the documentation on file and in the defensive memoranda, it is observed that:

1. the data controller is, in particular, required to comply with the principles regarding data protection, among which is the principle of "integrity."

the absence of protective measures, exposes personal data to unauthorized access) does not meet the requirements set forth in the applicable regulations.

5. Therefore, the treatment of personal data, as conducted by the Company, is deemed unlawful due to the failure to implement adequate security measures to protect the data from unauthorized access or accidental loss, as required by Article 32 of the Regulation. The lack of a password or encryption for the transmission of sensitive information, such as medical reports, constitutes a breach of the principles of data protection by design and by default, as outlined in Article 25 of the Regulation.

6. In light of the above considerations, it is concluded that the treatment of personal data by the Company does not comply with the legal obligations established by the Regulation, particularly regarding the security of processing and the protection of the rights of data subjects. Consequently, the Authority must take appropriate measures to ensure compliance and protect the rights of individuals affected by this unlawful treatment.

7. Recommendations: The Company is advised to implement the following measures to ensure compliance with data protection regulations:

1. Establish and enforce strict security protocols for the transmission of personal data, including the use of encryption and secure passwords.
2. Conduct regular assessments of the security measures in place to ensure they are adequate and effective in protecting personal data.
3. Provide training for staff on data protection and security measures to raise awareness and ensure compliance with legal obligations.
4. Review and update privacy policies to reflect current practices and ensure transparency with data subjects regarding their rights and the handling of their personal data.

8. Final Note: The Company is reminded that compliance with data protection regulations is not only a legal obligation but also essential for maintaining the trust of clients and stakeholders. Failure to address these issues may result in further regulatory action and potential penalties.

In any case, it cannot be equated to an express and conscious request from the same) does not relieve the data controller from the obligation to continuously assess, over time, an adequate level of security that also takes into account technological developments and new risks associated with processing for the rights and freedoms of the data subjects.

The Company has, therefore, failed to comply with the security obligations of processing, having not adopted appropriate technical and organizational measures to ensure a level of security adequate to the risks presented by the processing, in violation of the basic principles of processing as per Articles 5, paragraph 2, letter f), 25, paragraph 1, and 32 of the Regulation.

For these reasons, the illegality of the processing of personal data carried out by the Company is noted, as outlined in the reasoning, for the violation of Articles 5, paragraph 1, letter f), 25, and 32 of the Regulation.

In this context, considering that the conduct has exhausted its effects (the Company has, in fact, requested the recipient to whom the report was erroneously transmitted to delete it and has received assurances in this regard) and taking into account that the data controller has stated that a cryptographic code will be provided to clients for access to the report, attached to the recipient's email, the conditions for the adoption of corrective measures as per Article 58, paragraph 2, of the Regulation are not currently met.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i) and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, paragraph 1, letter f), 25, and 32 of the Regulation caused by the conduct of the Company is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraph 4, letter a) and paragraph 5, letter a) of the Regulation.

The Authority, pursuant to Articles 58, paragraph 2, letter i) of the Regulation and Article 166 of the Code, has the power to impose an administrative pecuniary sanction provided for by Article 83 of the Regulation, through the adoption of an injunction order (Article 18, Law No. 689 of November 24, 1981), in relation to the processing of personal data carried out by the Company, which has been found to be unlawful, as outlined above.

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation where it states that “if, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this Regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation,” the total amount of the sanction is calculated so as not to exceed the maximum provided for by the same Article 83, paragraph 5.

In light of the above and, in particular, of the category of personal data involved in the violation which, by their nature, are particularly sensitive in terms of fundamental rights and freedoms, as well as the number of potentially affected subjects, it is believed that the level of severity of the violation committed by the Company is high (cf. European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60).

That said, certain elements are assessed as a whole, and in particular, that:

- The Authority became aware of the event following a complaint from a data subject (Article 83, paragraph 2, letter h) of the Regulation);
- The data controller, in order to prevent the recurrence of the event that occurred, has committed to introducing measures aimed at increasing the level of security of the processing in question and reducing the replicability of the event that occurred and has adopted measures to remedy the violation and mitigate its possible negative effects (Article 83, paragraph 2, letters c) and f) of the Regulation);
- The data controller has cooperated with the Authority and has not been subject to previous measures from the Authority for relevant violations (Article 83, paragraph 2, letters f) and e) of the Regulation).

It is also considered that the economic conditions of the offender, determined based on the Company's turnover as per the financial statements for the year 2023, are relevant in this case.

In light of the above elements and the assessments made, it is deemed appropriate, in this specific case, to determine the amount of the pecuniary sanction at €7,000.00 (seven thousand/00) for the

violation of Articles 5, 25, and 32 of the same Regulation, based on the principles of effectiveness, proportionality, and deterrence to which the Authority must adhere, pursuant to Article 83, paragraph 1, of the Regulation.

In this context, it is also deemed necessary, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019, to proceed with the publication of this section containing the injunction order on the Authority's website. This is in consideration of the type of personal data subject to unlawful processing and the fact that the regulations regarding online reporting date back to 2009 and 2013.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

pursuant to Articles 57, paragraph 1, letter f) and 83 of the Regulation, notes the illegality of the processing carried out by Bios S.p.A., based in Via Domenico Chiellini, 39, 00197 Rome, Tax Code 01014021008, as outlined in the reasoning, for the violation of Articles 5, 25, and 32 of the Regulation;  
ORDERS

pursuant to Article 58, paragraph 2, letter i) of the Regulation, the same Company, represented by its legal representative pro tempore, to pay the sum of €7,000.00 (seven thousand) as an administrative financial penalty for the violation indicated in this provision.

REQUIRES

the aforementioned Company to pay the sum of €7,000.00 (seven thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions pursuant to Article 27 of Law No. 689/1981. It is noted that pursuant to Article 166, paragraph 8 of the Code, the offender retains the option to settle the dispute by paying - always according to the methods indicated in the attachment - an amount equal to half of the imposed penalty within the term referred to in Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011, provided for the submission of the appeal as indicated below.

ORDERS

- a) pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the Guarantor's website;
- b) pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Regulation of the Guarantor No. 1/2019, the publication of this provision on the Authority's website;
- c) pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree

No. 150/2011, against this provision it is possible to file an appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, October 17, 2024

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Scorza

THE SECRETARY GENERAL

Mattei